CHAPTER 3

RESEARCH QUESTIONS AND OBJECTIVES

3.1 Introduction

Chapter 2 reviewed the literature on multi-party consent and trustworthy data sharing in healthcare and found that the conditions for a trustworthy access decision exist in the literature but are never joined in one decision that is evaluated at every request, and that where they are joined the decision is neither proved nor tested. This chapter turns that finding into the research problem of the thesis. Section 3.2 states the research gap, first as a whole and then as six requirement-level gaps. Section 3.3 defines the terms used in the rest of the thesis: the patient, the guardian set, the threshold, the requester and the consent object. Section 3.4 states the main research question and the six sub-research questions, and shows that they form one integrated problem rather than six separate ones. Section 3.5 states the six research objectives and the relationship between each objective and its question. Section 3.6 concludes the chapter.

3.2 Gaps in the Literature

From a thorough review of the existing literature documented in Chapter 2, we have identified the following six gaps:

1. There is no existing representation of patient consent that carries the identity, authority, threshold, policy, temporal and lifecycle conditions of access as one evaluable object. Consent is recorded as a permission, and the evaluable objects that exist carry only a subset of the conditions and are issued by a single party.
2. There is no method that verifies the authority of a participant separately from the authentication of that participant within the same access decision, so a valid identity is taken as permission.
3. There is no mechanism by which multi-party approval, with the approving set defined by the patient, is a standing condition of every access decision rather than a contingency path, an admission gate or a registration-time co-consent.
4. There is no enforcement that binds the purpose and the data scope of a request to the same decision as identity, authority and collective approval.
5. There is no evaluation of temporal validity, lifecycle state and revocation at the moment of each access request; where they exist, they are enforced on a credential or at registration.
6. There is no formal definition or systematic testing of the complete authorisation decision under valid, invalid and adversarial conditions; any proof covers only a fragment of it.

3.3 Key Definitions

The patient, as the data subject, may create a consent specification and identify the relevant healthcare participant, authorised purpose, permitted data categories, and required approval conditions. The guardian set G is the set of designated participants whose independent approval is required. Depending on the consent configuration, G may contain healthcare professionals, guardians, institutional representatives, or other authorised parties. In the current prototype, the members of G are guardians. Each member of G is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. The threshold N is the number of valid approvals from members of G needed for activation. If the number of valid approvals is below the required threshold N, the consent cannot produce an effective authorisation decision. The authorised doctor D is the requester whose access request R is evaluated against the consent object C.

The consent object against which these questions are evaluated is defined in Equation (3.1), where I represents identity information, A represents authority and authorisation requirements, P represents policy and data-scope constraints, and E represents authorisation evidence. Within A, the guardian set G and the threshold N define the required approvals. T is the temporal validity window, and L represents the current state of the consent object and its permissible transitions, including whether the consent remains active or has been revoked. This formulation changes the role of consent from a passive record into an evaluable authorisation object.

$$C = (I, A, P, T, L, E) \tag{3.1}$$

3.4 Research Questions

From the systematic literature review documented in Chapter 2, and the shortcomings outlined in Section 2.4.7, it is clear that there are several gaps in the existing literature on trustworthy multi-party consent authorisation for healthcare data sharing.

Based on the identified research gap, the overarching research question is formulated as follows: **"How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints?"** The formulation of this question deliberately emphasises trust-oriented computing rather than any individual implementation technology. The terms establish and enforce represent two complementary aspects of the research problem. Establishment concerns how trustworthy participants, authority relationships, and collective consent decisions are created. Enforcement concerns how these established conditions are evaluated when a healthcare data-access request is made.

The research objectives are operationalised through six corresponding sub-research questions. Each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework. For brevity, SRQ1 to SRQ6 are referred to as RQ1 to RQ6 throughout this thesis.

- **SRQ1 (Trust-Centric Consent Modelling):** How can patient consent be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints, and authorisation evidence?
- **SRQ2 (Decentralised Identity and Authority Trust):** How can decentralised identities and verifiable credentials establish trustworthy participants while explicitly separating identity authentication from authorisation authority?
- **SRQ3 (Trustworthy Multi-Party Authorisation):** How can multiple independently verified participants jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access?

- **SRQ4 (Policy- and Context-Aware Access Control):** How can policy, purpose, and data-scope constraints be incorporated into authorisation decisions so that valid identities and sufficient approvals cannot be used to obtain unauthorised healthcare data?
- **SRQ5 (Temporal and Lifecycle Trust):** How can temporal validity and consent lifecycle controls ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and is rejected after expiration, revocation, or an unauthorised state transition?
- **SRQ6 (Formal Security Assurance and Empirical Validation):** How can the security properties of the proposed trust-oriented authorisation mechanism be formally defined and empirically evaluated to demonstrate that the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions?

3.4.1 Research Questions as an Integrated Problem

The six sub-research questions are not independent technical questions. RQ1 establishes the conceptual object. RQ2 establishes the trustworthiness of the participants. RQ3 then extends this participant-level trust into a collective decision. RQ4 determines whether the resulting authorisation is applicable to the specific data-access request. RQ5 further introduces the dynamic dimension of trust by determining whether the authorisation remains valid with respect to its temporal conditions and lifecycle state. Finally, RQ6 establishes the assurance layer by formally defining the resulting security properties and empirically evaluating whether the implemented framework enforces them correctly. The integrated authorisation condition can therefore be expressed as Equation (3.2). Here, V_I represents identity and authority validity, V_A collective authorisation validity, V_P policy and contextual compliance, V_T temporal validity, and V_L consent lifecycle validity.

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \tag{3.2}$$

A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Consequently, failure of any individual condition results in denial. In the prototype, an ALLOW decision additionally requires the exploratory jurisdiction check V_J (Chapter 8) to pass and the Groth16 ZK proof (Groth 2016) to verify, so a request that satisfies the five predicates is still denied when either fails, as in Scenario 4 (Chapter 10) and attack A9 (Chapter 10). Formal security assurance does not constitute another authorisation condition to be evaluated at runtime. Instead, it provides a means of specifying, analysing, and verifying the security properties of the integrated authorisation mechanism. Thus, RQ6 operates as an assurance layer over the mechanisms established by RQ1–RQ5.

3.5 Research Objectives

The research objectives turn the research gap into concrete research and development activities. The complete research programme consists of six research objectives, corresponding to six research questions.

3.5.1 RO1: Trust-Centric Consent Model

The first research objective is to develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The model incorporates identity information, authority requirements, policy constraints, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made. RO1 directly addresses RQ1 and establishes the conceptual foundation for the remaining objectives. It defines the information that must be

represented before consent can be interpreted as an authorisation decision rather than merely as a static approval record.

3.5.2 RO2: Decentralised Identity and Authority Trust

The second research objective is to develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority. RO2 addresses RQ2 and provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data.

3.5.3 RO3: Trustworthy Multi-Party Authorisation

The third research objective is to develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants and guardians can jointly establish a trustworthy consent decision. The objective is to prevent unilateral authorisation where collective approval is required. The guardian set G, fixed at consent creation, defines which participants are eligible to contribute an approval to the authorisation process. Each participant must submit an approval that can be independently verified through EIP-712 signature recovery. Invalid approvals are rejected and must not contribute to the threshold count. In the current prototype, a valid signature is required from every listed guardian, so the threshold equals |G|, an N-of-N condition demonstrated in the 2-of-2 configuration. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold. RO3 addresses RQ3 and extends the consent model from an individual permission statement to a collective authorisation decision.

3.5.4 RO4: Policy- and Context-Aware Access Control

The fourth research objective is to develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent. The objective is to ensure that a valid identity and sufficient multi-party approval cannot be used to obtain healthcare information outside the authorised scope. A request is permitted only when the purpose is compatible with the consent and the requested data scope is a non-empty subset of the authorised EMR modules. In the current prototype, the request purpose is taken from the consent, so the purpose check confirms that the consent purpose is a supported healthcare use, while the comparison with a separately declared request purpose is left to the next stage. RO4 directly addresses RQ4 and completes the foundational authorisation model. Together, RO1–RO4 establish the representation, verification, collective authorisation, and policy-enforcement mechanisms required for a trust-oriented healthcare data-sharing decision.

3.5.5 RO5: Temporal and Lifecycle Trust

The fifth research objective is to extend the trust-oriented framework with temporal validity and consent lifecycle controls. The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced. RO5 addresses RQ5 and extends the foundational authorisation model into a dynamic consent environment. The current HALAH code already collects a start time and expiry time during consent creation. The prototype records them on-chain as notBefore and expiry within the consent token, enforces the temporal validity window at every access decision through V_T, implements end-to-end revocation, including an on-chain revoke transaction, and manages the consent through an explicit lifecycle state machine. Access can be granted only in the ACTIVE state, and V_L checks this state at every access decision. A consent that has expired or been revoked must not remain usable merely because its original approval threshold was satisfied. The remaining work concerns the

SUSPENDED state, the lifecycle transition check, a formal lifecycle model, and hardening these controls and extending them to consent modification, delegation, and guardian-set changes.

3.5.6 RO6: Formal Security Assurance and Empirical Validation

The sixth research objective is to formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios. RO6 addresses RQ6 and combines formal security assurance with empirical validation of the proposed framework. The prototype must execute valid consent workflows, and it must also behave correctly when one or more trust conditions are violated. RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH prototype. In particular, 46 automated tests cover signature rejection, proof tampering, credential checks, and twelve attack scenarios, A1 to A12, against the components of C and the contract. All twelve attacks are refused. Preliminary measurements of on-chain cost, confirmation latency, and processing time have been obtained, and a live out-of-jurisdiction request against a consent anchored on the deployed Sepolia contract was refused by the exploratory jurisdiction check of the application (Chapter 8). The formal component will specify and analyse the security properties, consistency requirements, and soundness conditions of the trust-oriented authorisation mechanism. Although preliminary implementation and scenario-based testing support the current stage findings, the complete formal analysis, through proofs or model checking, and a larger evaluation under load will be conducted as part of next stage works.

3.5.7 Relationship Between Research Questions and Objectives

The relationship between the six research questions and the six research objectives, with the status of each objective, is summarised in Table 3.1. The mapping follows the structure of the research programme and maintains a direct correspondence between each research question and its associated objective. RO1 to RO6 are realised in Chapter 5 to Chapter 10 respectively, each in the section presenting the solution for the corresponding research question. Because each research question corresponds to one gap identified in Chapter 2, each objective addresses the gap of the same number, so that RO1 addresses Gap 1 and RO6 addresses Gap 6. Each research question therefore has one research activity, and each objective contributes to the framework. RO1 to RO4 are delivered in this stage, together with their validation and evaluation through the implemented prototype, whereas, as stated in Chapter 1, RO5 is in progress and RO6 is partially completed. Their remaining work is detailed in Chapter 9 and Chapter 10, and its schedule is presented in Chapter 11. The distinction between current stage and next stage is therefore based on research scope and maturity rather than on a different set of research questions or objectives.

Table 3.1: Research questions, research objectives, and the status of each objective

RQ	Research objective	Description	Status
RQ1	RO1: Trust-Centric Consent Model	To develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object.	Done
RQ2	RO2: Decentralised Identity and Authority Trust	To develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials.	Done
RQ3	RO3: Trustworthy Multi-Party Authorisation	To develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants and guardians can jointly establish a trustworthy consent decision.	Done
RQ4	RO4: Policy- and Context-Aware Access Control	To develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent.	Done
RQ5	RO5: Temporal and Lifecycle Trust	To extend the trust-oriented framework with temporal validity and consent lifecycle controls.	In Progress
RQ6	RO6: Formal Security Assurance and Empirical Validation	To formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios.	Partially completed

3.6 Conclusion

This chapter stated the research problem. The gap found in Chapter 2 is the absence of an integrated model in which identity, authority, multi-party approval, policy, temporal validity and lifecycle state are evaluated together at every access request, with an approving set defined by the patient, and in which that joint decision is formally and empirically assured. The first five requirement-level gaps form the conjunction gap and the sixth forms the assurance gap.

From this gap, one main research question was stated: how a trust-oriented computing framework can establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority and policy constraints. The question was divided into six sub-research questions, one per gap, and each sub-research question was matched with one research objective. The six questions are not independent: the first defines the consent object, the second and third establish who may take part and how they decide together, the fourth and fifth decide whether a particular request is allowed now, and the sixth assures the whole. The next chapter presents the research methodology and an overview of the solution proposed for each question.